



Wiederholung 1: Unternehmenssicherheit bestimmen und Angriffsvektoren

Lernziele:

- Die klassischen sowie erweiterte Schutzziele erklären und einem konkreten Beispiel zuordnen.
- Eine qualitative und eine quantitative Methode zur Risikobewertung anwenden.
- Zu einem bewerteten Risiko eine passende Strategie der Risikobewältigung vorschlagen und begründen.
- Relevante rechtliche Rahmenbedingungen für ein gegebenes Unternehmen bestimmen und begründet gegeneinander abgrenzen.
- Ein Unternehmen anhand der CIS Critical Security Controls einer Implementation Group zuordnen und daraus fehlende Maßnahmen priorisieren.
- Authentication, Authorization und Accounting erklären und von zentralem beziehungsweise dezentralem Zugriffsmanagement abgrenzen.

1. Schutzziele: die erweiterte CIA-Triade

Die drei klassischen Schutzziele der Informationssicherheit sind bereits aus früheren Jahrgängen bekannt: **Confidentiality**, Vertraulichkeit, bedeutet, dass nur berechtigte Personen Informationen einsehen dürfen. **Integrity**, Integrität, bedeutet, dass Daten nicht unbemerkt verändert werden dürfen. **Availability**, Verfügbarkeit, bedeutet, dass Systeme und Daten bei Bedarf tatsächlich zugänglich sind. Zusammen bilden sie die CIA-Triade, das gemeinsame Grundgerüst praktisch jeder Sicherheitsbetrachtung.

Für Vorgänge mit rechtlicher Relevanz reicht diese Triade allein oft nicht aus, weshalb zwei erweiterte Schutzziele ergänzt werden. **Authenticity**, Echtheit, ist der Nachweis, dass eine Nachricht oder eine Identität tatsächlich von der behaupteten Quelle stammt. **Non-Repudiation**, Nichtabstreitbarkeit, bedeutet, dass eine Person eine von ihr tatsächlich durchgeführte Handlung im Nachhinein nicht glaubhaft bestreiten kann. Beide erweiterten Ziele hängen eng mit Accounting (siehe Abschnitt 5) sowie mit digitalen Signaturen zusammen und werden überall dort wichtig, wo im Streitfall nachgewiesen werden muss, wer wann welche Handlung tatsächlich gesetzt hat, etwa bei einer verbindlichen Bestellung oder einer dokumentierten Absprache zwischen zwei Vertragsparteien.

Ein Beispiel je Schutzziel, angewendet auf ein Online-Bestellsystem: **Confidentiality** verletzt, wenn ein Unbefugter die Kreditkartendaten anderer Kunden einsehen kann. **Integrity** verletzt, wenn eine



Bestellmenge auf dem Übertragungsweg unbemerkt verändert wird. **Availability** verletzt, wenn der Bestellschop durch einen DDoS-Angriff während eines Sale-Events nicht erreichbar ist. **Authenticity** verletzt, wenn sich jemand mit gestohlenen Zugangsdaten als ein anderer Kunde ausgibt. **Non-Repudiation** verletzt, wenn ein Kunde eine tatsächlich getätigte Bestellung im Nachhinein bestreitet und das System diese Behauptung mangels Nachweis nicht widerlegen kann (etwa fehlende signierte Bestellbestätigung mit Zeitstempel).

2. Schutzbedarf feststellen, dann Risiken bewerten und bewältigen

Bevor überhaupt einzelne Risiken bewertet werden können, muss zuerst der **Schutzbedarf** der betroffenen Werte (Assets) geklärt werden: wie schwerwiegend wäre es für das Unternehmen, wenn bei einem bestimmten Asset eines der Schutzziele aus Abschnitt 1 verletzt würde? Der Schutzbedarf wird dazu üblicherweise in Stufen eingeteilt, etwa **normal**, **hoch** und **sehr hoch**, getrennt je Schutzziel bewertet (ein Asset kann etwa bei Verfügbarkeit nur normalen, bei Vertraulichkeit aber sehr hohen Schutzbedarf haben). Ein interner Wiki-Server mit allgemeinen Anleitungen hat bei Vertraulichkeit typischerweise nur normalen Schutzbedarf, eine Datenbank mit Gesundheitsdaten von Kundinnen und Kunden dagegen sehr hohen. Erst mit dieser Einstufung lässt sich sinnvoll entscheiden, wie viel Aufwand eine konkrete Schutzmaßnahme für ein bestimmtes Asset rechtfertigt: ein Asset mit sehr hohem Schutzbedarf trägt und braucht aufwendigere, teurere Maßnahmen als eines mit lediglich normalem Schutzbedarf.

Risiko ergibt sich grundsätzlich aus dem Produkt von Eintrittswahrscheinlichkeit und Schadensausmaß. Für die konkrete Bewertung stehen zwei einander ergänzende Vorgehensweisen zur Verfügung.

Qualitative Bewertung: Eintrittswahrscheinlichkeit und Schadensausmaß werden in vorab definierten Stufen eingeschätzt, etwa niedrig, mittel und hoch, und in einer **Risikomatrix** gegenübergestellt. Damit „hoch“ oder „niedrig“ nachvollziehbar bleibt, muss vor der eigentlichen Bewertung festgelegt werden, welches konkrete Ereignis, welcher Zeitraum und welcher Schaden jeweils einer Stufe entsprechen, eine Einschätzung ohne eine solche vorab festgelegte Skala ist willkürlich und im Nachhinein nicht nachvollziehbar. Eine einfache 3×3-Matrix dazu:

Eintrittswahrscheinlichkeit \ Schaden	niedrig	mittel	hoch
hoch	mittel	hoch	sehr hoch
mittel	niedrig	mittel	hoch
niedrig	sehr niedrig	niedrig	mittel

Beispiel: Ein Unternehmen ohne Mehr-Faktor-Authentifizierung für Fernzugriffe schätzt die Eintrittswahrscheinlichkeit eines erfolgreichen Passwort-Diebstahls als **hoch** ein (Phishing ist alltäglich, ein einzelner Faktor bietet wenig Schutz), den daraus resultierenden Schaden als **mittel** (Zugriff auf ein einzelnes Nutzerkonto, nicht auf die gesamte Infrastruktur) — nach obiger Matrix ergibt das ein **hohes** Gesamtrisiko, das behandelt werden sollte.

Quantitative Bewertung: Dieselbe Überlegung lässt sich auch in konkreten Geldbeträgen ausdrücken, über die **Annual Loss Expectancy (ALE)**, das Produkt aus der **Single Loss Expectancy (SLE)**, dem geschätzten Schaden eines einzelnen Vorfalls, und der **Annual Rate of Occurrence (ARO)**, der geschätzten Häufigkeit eines solchen Vorfalls pro Jahr. Der resultierende ALE-Wert eignet sich gut, um eine geplante Sicherheitsinvestition wirtschaftlich zu begründen: liegen die jährlichen Kosten einer Gegenmaßnahme deutlich unter dem durch sie vermiedenen erwarteten Jahresschaden, ist die Investition wirtschaftlich gerechtfertigt. Beispiel: Ein Unternehmen schätzt, dass ein Ransomware-Vorfall im Schnitt einen Schaden von 40.000 € verursacht (SLE, aus Wiederherstellungskosten, Ausfallzeit und



Reputationsschaden), und rechnet laut Branchenstatistik mit einem solchen Vorfall alle zwei Jahre (ARO = 0,5). Daraus ergibt sich $ALE = 40.000 \text{ €} \times 0,5 = \mathbf{20.000 \text{ € erwarteter Schaden pro Jahr}}$. Kostet eine zusätzliche Backup- und Endpoint-Protection-Lösung 6.000 € pro Jahr, ist die Investition wirtschaftlich klar gerechtfertigt, da sie deutlich unter dem vermiedenen erwarteten Jahresschaden liegt.

Welche der beiden Methoden geeigneter ist, hängt von der verfügbaren Datenlage ab: Die qualitative Bewertung ist schneller und günstiger durchzuführen und kommt ohne verlässliche historische Zahlen aus, bleibt aber subjektiv und schwer exakt vergleichbar. Die quantitative Bewertung liefert ein konkretes, für eine Kosten-Nutzen-Rechnung direkt verwendbares Ergebnis, setzt dafür aber realistische SLE-/ARO-Schätzwerte voraus, die in der Praxis oft nur ungenau vorliegen (etwa mangels ausreichender eigener Vorfallshistorie) — beide Methoden werden daher in der Praxis häufig kombiniert, etwa qualitativ zur groben Priorisierung vieler Risiken und quantitativ zur genaueren Begründung einzelner, besonders teurer Gegenmaßnahmen.

Strategien der Risikobewältigung: Nach der Bewertung eines Risikos stehen grundsätzlich vier Strategien zur Wahl. **Vermeidung** bedeutet, die risikobehaftete Tätigkeit oder Konfiguration gar nicht erst einzugehen oder vollständig einzustellen. **Verminderung** bedeutet, durch technische oder organisatorische Maßnahmen entweder die Eintrittswahrscheinlichkeit oder das Schadensausmaß gezielt zu senken, in der Praxis die mit Abstand häufigste Strategie. **Transfer** bedeutet, das Risiko ganz oder teilweise an einen Dritten zu übertragen, etwa über eine Cyberversicherung oder durch Auslagerung an einen spezialisierten Dienstleister. **Akzeptanz** bedeutet schließlich, ein Risiko bewusst und dokumentiert hinzunehmen, meist weil die Kosten einer weiteren Behandlung den möglichen Schaden übersteigen würden oder weil nach Anwendung der anderen drei Strategien ein bewusst tragbares Restrisiko übrig bleibt.

3. Rechtliche Rahmenbedingungen im Überblick

Welche rechtlichen Vorgaben für ein Unternehmen tatsächlich gelten, hängt von dessen Größe, Branche und den verarbeiteten Daten ab, eine pauschale Anwendung aller bekannten Regulationen auf jedes Unternehmen wäre fachlich falsch.

Datenschutz-Grundverordnung (DSGVO): Gilt EU-weit für praktisch jede Organisation, die personenbezogene Daten verarbeitet, unabhängig von Größe oder Branche, und über das sogenannte Marktortprinzip sogar für Unternehmen außerhalb der EU, sobald sie Daten von EU-Bürgerinnen und -Bürgern verarbeiten. Zu den wichtigsten Pflichten zählen: eine gültige Rechtsgrundlage für jede Verarbeitung (etwa Einwilligung oder Vertragserfüllung), die Wahrung der Betroffenenrechte (u. a. Auskunft, Löschung, Datenübertragbarkeit), ein Verzeichnis von Verarbeitungstätigkeiten, eine Meldung von Datenschutzverletzungen an die Aufsichtsbehörde binnen 72 Stunden, sowie unter bestimmten Voraussetzungen (etwa umfangreiche systematische Überwachung) die Bestellung eines Datenschutzbeauftragten. Verstöße können mit Bußgeldern bis zu 20 Millionen Euro oder 4 % des weltweiten Jahresumsatzes geahndet werden, je nachdem, welcher Betrag höher ist.

NIS-2-Richtlinie: Betrifft Unternehmen bestimmter, in eigenen Anhängen gelisteter Sektoren (etwa Energie, Verkehr, Gesundheitswesen und digitale Infrastruktur als „wesentliche Einrichtungen“, Post-/Kurierdienste, Abfallwirtschaft oder Lebensmittelproduktion als „wichtige Einrichtungen“) ab festgelegten Größenschwellen (im Regelfall ab 50 Mitarbeitenden oder 10 Millionen Euro Jahresumsatz). Zu den Pflichten zählen verbindliche Risikomanagementmaßnahmen (u. a. Vorfallsbehandlung, Business-Continuity-Planung, Absicherung der Lieferkette), eine gestufte Meldepflicht bei erheblichen Sicherheitsvorfällen (Frühwarnung binnen 24 Stunden, vollständige Meldung binnen 72 Stunden), sowie eine persönliche Verantwortung der Geschäftsführung für die Umsetzung. Wesentliche Einrichtungen unterliegen einer strengeren Aufsicht (u. a. proaktive Prüfungen) und höheren Bußgeldrahmen (bis 10



Millionen Euro oder 2 % des weltweiten Jahresumsatzes) als wichtige Einrichtungen (bis 7 Millionen Euro oder 1,4 %).

Digital Operational Resilience Act (DORA): Beschränkt sich ausschließlich auf den Finanzsektor (Banken, Versicherungen, Wertpapierfirmen, Zahlungsdienstleister, Krypto-Asset-Dienstleister u. a.) sowie deren kritische IKT-Drittdienstleister, etwa große Cloud-Anbieter, die dadurch direkt mitbeaufsichtigt werden — ein wichtiges Beispiel dafür, dass eine neue EU-Regulation zu Cyberbeziehungsweise operationeller Resilienz nicht automatisch für jedes Unternehmen gilt. Zu den Pflichten zählen ein umfassendes IKT-Risikomanagement-Rahmenwerk, eine einheitliche Klassifizierung und Meldung von IKT-Vorfällen, regelmäßige Resilienztests (bei größeren Instituten inklusive bedrohungsorientierter Penetrationstests, TLPT) sowie ein striktes Management von Risiken durch IKT-Drittanbieter, einschließlich verpflichtender Vertragsklauseln.

EU AI Act: Reguliert Anbieter und Betreiber von KI-Systemen, die auf dem EU-Markt angeboten oder in der EU genutzt werden, abgestuft nach vier Risikokategorien: unannehmbares Risiko (verboten, etwa Social Scoring oder biometrische Echtzeit-Fernidentifizierung im öffentlichen Raum), Hochrisiko (etwa Systeme zur Personalauswahl oder Kreditwürdigkeitsprüfung, verpflichtend u. a. Risikomanagement, Dokumentation, menschliche Aufsicht und eine Konformitätsbewertung vor Markteinführung), begrenztes Risiko (bloße Transparenzpflichten, etwa eine Kennzeichnungspflicht für Chatbots und Deepfakes) und minimales Risiko (keine besonderen Auflagen, etwa ein gewöhnlicher Spamfilter). Die Verordnung wird erst relevant, sobald ein Unternehmen tatsächlich ein entsprechendes System einsetzt, und tritt stufenweise zwischen 2025 und 2027 vollständig in Kraft.

eIDAS-Verordnung: Regelt elektronische Identifizierung und Vertrauensdienste (elektronische Signaturen, Siegel, Zeitstempel, Zustelldienste) im EU-Binnenmarkt und wird relevant, sobald ein Unternehmen elektronische Signaturen mit Rechtswirkung einsetzen möchte. Sie unterscheidet drei Vertrauensstufen elektronischer Signaturen, von denen nur die **qualifizierte elektronische Signatur (QES)** EU-weit einer handschriftlichen Unterschrift rechtlich gleichgestellt ist; die dafür nötigen Vertrauensdiensteanbieter müssen ein Konformitätsbewertungsverfahren durchlaufen und werden von einer nationalen Aufsichtsstelle überwacht. Die aktuelle Fassung (eIDAS 2.0) führt zusätzlich die European Digital Identity Wallet ein, eine EU-weit anerkannte digitale Brieftasche für amtliche Nachweise.

Cyber Resilience Act (CRA): Betrifft, anders als NIS-2 (das regelt, wie Unternehmen ihre IT sicher **betreiben**), Hersteller, Importeure und Händler von **Produkten mit digitalen Elementen** (Hardware und Software mit Datenverbindung, von Smart-Home-Geräten bis zu gewöhnlichen Softwareanwendungen), die auf dem EU-Markt in Verkehr gebracht werden — es regelt also, wie solche Produkte sicher **entwickelt** werden. Zu den Pflichten zählen „Security by Design and by Default“ über den gesamten Produktlebenszyklus, ein systematisches Schwachstellenmanagement, eine gestufte Meldepflicht (Frühwarnung binnen 24 Stunden, vollständige Meldung binnen 72 Stunden) für aktiv ausgenutzte Schwachstellen und schwerwiegende Sicherheitsvorfälle an die zuständige Behörde, sowie die Bereitstellung von Sicherheitsupdates über einen angemessenen Support-Zeitraum. Je nach Risikoklasse des Produkts (gewöhnlich, „wichtig“ oder „kritisch“, etwa Betriebssysteme, Firewalls oder Passwort-Manager) gelten unterschiedlich strenge Konformitätsbewertungsverfahren vor der CE-Kennzeichnung. Verstöße gegen die grundlegenden Sicherheitsanforderungen können mit Bußgeldern bis zu 15 Millionen Euro oder 2,5 % des weltweiten Jahresumsatzes geahndet werden.

Zur richtigen Prüfung gehört ausdrücklich auch das Ausschlussverfahren: für ein gegebenes Unternehmen ist ebenso zu begründen, welche auf den ersten Blick naheliegende Regulation bei genauerer Betrachtung tatsächlich **nicht** zutrifft. Ein Fahrradgeschäft mit fünf Mitarbeitenden etwa unterliegt der DSGVO (es verarbeitet Kundendaten), fällt aber weder unter NIS-2 (kein gelisteter Sektor, weit unter den Größenschwellen) noch unter DORA (keine Finanzdienstleistung) noch unter den Cyber Resilience Act (es stellt selbst keine Produkte mit digitalen Elementen her, sondern verkauft nur fremde



Fahrräder).

4. Risikobasiertes Sicherheitskonzept nach CIS Controls

Die **CIS Critical Security Controls** sind ein praxisorientiertes, priorisiertes Rahmenwerk mit 18 übergeordneten Controls, die insgesamt in konkrete Einzelmaßnahmen, die **Safeguards**, aufgeschlüsselt sind. Um nicht jedes Unternehmen mit sämtlichen Safeguards gleichermaßen zu überfordern, sind diese in drei **Implementation Groups (IG)** gestaffelt: **IG1** umfasst die grundlegenden Safeguards als essenzielle Cyberhygiene, die praktisch für jedes Unternehmen sinnvoll sind. **IG2** baut kumulativ darauf auf und richtet sich an Unternehmen mit mehr IT-Komplexität und Ressourcen. **IG3** umfasst kumulativ alle Safeguards und richtet sich an Unternehmen mit hohem Risikoprofil und einem dedizierten Sicherheitsteam.

Welche Implementation Group für ein konkretes Unternehmen passt, wird anhand mehrerer Kriterien gemeinsam entschieden: Unternehmensgröße und verfügbare IT-/Sicherheitsressourcen, Branche und regulatorisches Risikoprofil (siehe Abschnitt 3), sowie Art und Sensibilität der verarbeiteten Daten. Ein kleiner Handwerksbetrieb ohne eigene IT-Abteilung würde dabei typischerweise in IG1 eingestuft, ein mittelständisches, NIS-2-pflichtiges Logistikunternehmen mit eigener IT-Abteilung eher in IG2, und ein Krankenhaus mit sensiblen Patientendaten und einem dedizierten Sicherheitsteam eher in IG3. Nach dieser Einstufung wird geprüft, welche der zugehörigen Safeguards im Unternehmen bereits, auch nur teilweise, umgesetzt sind, und welche noch fehlen. Jede so gefundene Lücke lässt sich einem der zuvor identifizierten Risiken zuordnen und danach priorisieren, wie dringend sie im Vergleich zu anderen Lücken zu schließen ist, üblicherweise danach, ob das zugehörige Risiko bereits eingetreten ist oder unmittelbar naheliegt.

Die Nummerierung der Safeguards folgt dabei immer dem Schema „Control.Safeguard“, ein Safeguard wie 6.7 bezeichnet also den siebten Safeguard innerhalb von Control 6. Die 18 Controls im Überblick:

Nr.	Control	Nr.	Control
1	Inventory and Control of Enterprise Assets	10	Malware Defenses
2	Inventory and Control of Software Assets	11	Data Recovery
3	Data Protection	12	Network Infrastructure Management
4	Secure Configuration of Enterprise Assets and Software	13	Network Monitoring and Defense
5	Account Management	14	Security Awareness and Skills Training
6	Access Control Management	15	Service Provider Management
7	Continuous Vulnerability Management	16	Application Software Security



Nr.	Control	Nr.	Control
8	Audit Log Management	17	Incident Response Management
9	Email and Web Browser Protections	18	Penetration Testing

Für die konkrete Zuordnung im Aufgabenblatt genügt es, eine vorhandene oder fehlende Maßnahme sinngemäß einem dieser 18 Controls zuzuordnen (Nummer und Name) und die fehlende Maßnahme so konkret zu benennen, dass sie sich als eigener Safeguard formulieren ließe, etwa „Control 7, Continuous Vulnerability Management: es fehlt ein automatisiertes Patch-Management für öffentlich erreichbare Server“ statt nur „es fehlen Updates“.

5. Zugriffs- und Berechtigungskonzept: AAA und Zero Trust

Authentication, Authentifizierung, ist der Nachweis der eigenen Identität, im Kern die Frage „wer bin ich“. **Authorization**, Autorisierung, ist die anschließende Vergabe konkreter Rechte, die Frage „was darf ich“. **Accounting**, Protokollierung, hält fest, welche Handlung tatsächlich durchgeführt wurde, die Frage „was habe ich getan“, und bildet damit die technische Grundlage für die in Abschnitt 1 genannten Schutzziele Authenticity und Non-Repudiation: Ohne ein funktionierendes Accounting lässt sich im Streitfall oder bei einem Sicherheitsvorfall nicht nachvollziehen, welches Konto welche Aktion tatsächlich gesetzt hat.

Eine AAA-Umsetzung gilt als **zentral**, wenn Authentifizierung, Rechtevergabe und Protokollierung einheitlich über ein gemeinsames System erfolgen, etwa einen zentralen Verzeichnisdienst. Sie gilt als **dezentral**, wenn einzelne Systeme eigene, voneinander unabhängige Konten und Rechte verwalten, oder wenn, wie in der Praxis nicht selten anzutreffen, mehrere Personen sich einen gemeinsamen Sammel-Account teilen. Ein Sammel-Account ist besonders kritisch zu bewerten, da er ein individuelles Accounting faktisch unmöglich macht: lässt sich eine Handlung nur noch auf einen geteilten Account, nicht aber auf eine einzelne Person zurückführen, ist weder Non-Repudiation noch eine spätere Vorfallaufklärung in vollem Umfang möglich.

Je nach Zugriffsszenario eignen sich unterschiedliche Authentifizierungsfaktoren, klassisch unterschieden nach Wissen (etwa ein Passwort), Besitz (etwa ein Hardware-Token oder ein Mobiltelefon) und Inhärenz (ein biometrisches Merkmal). Ein einfacher Arbeitsplatz-Login kommt oft mit einem einzelnen Faktor aus, ein Fernzugriff von außerhalb des Unternehmensnetzes sollte dagegen grundsätzlich mindestens zwei unabhängige Faktoren kombinieren (Mehr-Faktor-Authentifizierung), da hier zusätzliche Risiken (etwa ein unsicheres Heimnetzwerk) hinzukommen.

Das klassische AAA-Modell setzt dabei implizit voraus, dass einer Person innerhalb des Unternehmensnetzes nach einer einmaligen Authentifizierung grundsätzlich vertraut wird. Das modernere **Zero-Trust-Paradigma** verzichtet bewusst auf dieses implizite Vertrauen: jede einzelne Anfrage wird unabhängig davon, ob sie aus dem internen Netz oder von außen kommt, erneut anhand von Identität, Gerätezustand und Kontext geprüft, statt sich auf einen einmal erfolgreich durchlaufenen Netzwerkübergang zu verlassen. Im klassischen Modell genügt einer Mitarbeiterin nach dem morgendlichen VPN-Login ein einziger Vertrauensbeweis, um den ganzen Tag über auf sämtliche interne Systeme zuzugreifen; in einer Zero-Trust-Umgebung wird dagegen bei jedem einzelnen Zugriff, etwa auf einen bestimmten Fileserver, erneut geprüft, ob Identität, Gerät und Kontext dafür passen. Ein gestohlenes, aber bereits eingeloggtes Gerät bekommt dadurch nicht automatisch Zugriff auf alles, sondern nur so weit, wie die jeweils erneute Prüfung dies zulässt.



Aufgabenblatt

Im zugehörigen Aufgabenblatt wenden Sie Schutzziele, Risikobewertung, rechtliche Einordnung, CIS-Controls-Zuordnung und AAA-Konzept auf ein konkretes Unternehmen an: im gemeinsamen Unterricht anhand des Plenums-Unternehmens, danach als Hausübung eigenständig anhand des jeweils eigenen Gruppen-Unternehmens.